

Clase 174 — Compromiso total de dominio: DCSync y Golden Ticket

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *The Hacker Recipes / MITRE ATT&CK T1003.006, T1558.001* 🕒 Duración estimada: **110 min** · Nivel: **Experto**

🎯 Objetivo

Ejecutar las técnicas que representan el "game over" de un dominio: DCSync (replicar el directorio para robar todos los hashes, incluido el de `krbtgt`) y Golden Ticket (forjar un TGT válido para cualquier usuario). El alumno comprenderá por qué estas técnicas otorgan control total y persistente, y cómo se detectan pese a su sigilo.

📖 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Ejecutar** DCSync para extraer el hash de `krbtgt` y de cualquier cuenta.
2. **Forjar** un Golden Ticket y usarlo para acceso arbitrario.
3. **Explicar** por qué `krbtgt` es la clave maestra del dominio.
4. **Distinguir** Golden Ticket de Silver Ticket.
5. **Detectar** DCSync y tickets forjados con la telemetría adecuada.

📖 Temas

#	Tema	Por qué importa
1	Derechos de replicación	Base del abuso DCSync
2	DCSync (T1003.006)	Robar hashes sin tocar el DC directamente
3	El hash de krbtgt	Clave para forjar TGTs
4	Golden Ticket (T1558.001)	TGT forjado = acceso total
5	Silver Ticket	TGS forjado para un servicio
6	Persistencia y peligro	Sobrevive a cambios de contraseña
7	Detección	DCSync y tickets anómalos

📖 Definiciones y características

- **DCSync**: abusar de los derechos de replicación (`DS-Replication-Get-Changes`) para pedir al DC los hashes. Característica: se ve como replicación legítima entre DCs.
- **krbtgt**: cuenta cuyo hash cifra todos los TGT del dominio. Característica: quien lo tiene, forja identidad de cualquiera.

- **Golden Ticket:** TGT forjado con el hash de krbtgt. Característica: acceso total, válido hasta cambiar krbtgt (dos veces).
- **Silver Ticket:** TGS forjado con el hash de una cuenta de servicio. Característica: acceso a un servicio concreto, más sigiloso.
- **Derechos de replicación:** permisos que normalmente tienen los DCs (y DA). Característica: si un usuario los obtiene, puede DCSync.
- **KRBTGT reset:** cambiar dos veces la contraseña de krbtgt invalida golden tickets. Característica: única remediación real tras el compromiso.

Herramientas y preparación

- AD lab / GOAD con una cuenta que tenga (o a la que hayas concedido, vía una ruta de BloodHound) derechos de replicación.
- **Impacket** `secretsdump.py` para DCSync; **Mimikatz** para DCSync y forja de tickets; **Rubeus** como alternativa.
- Acceso previo con privilegios altos (DA o equivalente) obtenido en las clases anteriores.

⚠ Estas son las técnicas más críticas del curso: se practican **exclusivamente** en tu AD lab / GOAD. Un Golden Ticket real es un compromiso catastrófico. Nunca las uses fuera de un laboratorio propio o un engagement con autorización escrita explícita.

Laboratorio guiado

1. **Verifica los derechos.** Confirma que tu cuenta (o una ruta de BloodHound) tiene `DS-Replication-Get-Changes-ALL`.
2. **DCSync con Impacket:**

```
bash secretsdump.py lab.local/dauser:pass@10.10.10.10 -just-dc-user krbtgt
```

Extrae el hash NTLM de `krbtgt` (y de cuentas objetivo). 3. **Anota el SID del dominio:** `Get-DomainSID` o con `lookupsid.py`. 4. **Forja el Golden Ticket (Mimikatz):**

```
text kerberos::golden /user:Administrator /domain:lab.local /sid:<DOMAIN_SID> /krbtgt:<HASH> /ptt
```

5. **Usa el ticket.** Con el TGT forjado inyectado, accede al DC: `dir \\dc01.lab.local\C$` o `psexec.py` sin credenciales adicionales.
6. **Silver Ticket (comparación).** Forja un TGS para un servicio concreto (CIFS) con el hash de la cuenta de máquina y observa que es más sigiloso (no pasa por el DC para el TGS).
7. **Detección.** Revisa el evento `4662` (acceso a objeto con GUID de replicación) para DCSync y anomalías en la vida/PAC de los tickets para Golden Ticket.

Ejercicios

1. Explica por qué el hash de krbtgt permite forjar identidad de cualquier usuario.
2. Ejecuta DCSync y extrae el hash de krbtgt del lab.
3. Forja un Golden Ticket y accede al DC.
4. Forja un Silver Ticket y compáralo con el Golden en sigilo.

5. Explica por qué hay que resetear krbtgt dos veces.
6. Escribe la lógica de detección basada en el evento 4662.

Reto verificable

Logra **acceso total al DC de tu AD lab** mediante DCSync + Golden Ticket: extrae el hash de krbtgt, forja un TGT de Administrator y úsalo para leer un recurso del DC sin credenciales adicionales. **Criterio de aceptación:** muestras el hash de krbtgt obtenido por DCSync, el comando de forja del Golden Ticket y una acción con éxito sobre el DC usando ese ticket; además identificas el evento 4662 que delató la replicación. Todo en tu laboratorio.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
DCSync <code>access denied</code>	Falta el derecho de replicación; usa una cuenta/ruta que lo tenga
Golden Ticket no funciona	SID o hash de krbtgt incorrectos; verifica ambos
El ticket expira raro	Vida por defecto muy larga delata; ajusta tiempos realistas
Silver no accede	Hash o SPN equivocado; usa el hash de la cuenta correcta
Detectado por 4662	DCSync desde un host no-DC es anómalo; asúmelo como telemetría

Preguntas frecuentes

-  **¿Por qué DCSync no "toca" el DC como un dump?** Porque usa el protocolo de replicación legítimo (MS-DRSR): pide los datos como lo haría otro DC. Por eso es sigiloso, aunque el evento 4662 lo revela.
-  **¿Cambiar la contraseña de Administrator invalida el Golden Ticket?** No. Solo resetear krbtgt (dos veces) invalida los golden tickets. Por eso es la peor persistencia posible.
-  **¿Golden o Silver Ticket?** Golden da acceso total pero es más detectable; Silver es acotado a un servicio pero más sigiloso porque no solicita TGS al DC.

Referencias

- The Hacker Recipes — *DCSync / Kerberos tickets*. <https://www.thehacker.recipes/ad/movement/>
- MITRE ATT&CK — *DCSync* (T1003.006), *Golden Ticket* (T1558.001). <https://attack.mitre.org/>
- Impacket `secretsdump`. <https://github.com/fortra/impacket>
- Microsoft — *KRBtgt account maintenance*. <https://learn.microsoft.com/>

Siguiente clase

Clase 175 - Persistencia en Active Directory